TECHNICAL & LEGAL COMPLIANCE WHITEPAPER

REF: FGF-SEC-IP-COMPLIANCE-2026

# FGF GUILD MANAGEMENT

Technical Architecture, Security, Privacy by Design & Intellectual Property Compliance Whitepaper

**Purpose of this Document**

Prepared for the **Game Publisher, Developer, Legal Counsel and Community Operations teams**. It describes an independent, free, out-of-game companion tool that does **not interact with the game client or its network traffic**, uses **no copyrighted game assets**, processes a **limited, published set of personal data**, and isolates every guild with **PostgreSQL 17 Row-Level Security**.

| 0 | 0 | 0 | 100% |
|---|---|---|---|
| COPYRIGHTED GAME ASSETS | GAME MEMORY / CLIENT HOOKS | PAYMENTS, COOKIES OR ANALYTICS | PUBLIC TABLES UNDER RLS + FORCE RLS |

TARGET AUDIENCE
Game Publisher & Developer Compliance / Security Teams

DOCUMENT VERSION
3.0 (supersedes the August 2026 edition)

FRAMEWORKS
GDPR (EU 2016/679), OWASP Top 10, Zero-Trust Access

REVISED
October 4, 2026

© 2026 FGF Guild Management Platform — Unofficial Community Companion Tool

Compliance Whitepaper

## Table of Contents

1. Executive Summary & Scope
2. Personal Data & Privacy by Design (GDPR)
3. Intellectual Property, Asset & Trademark Safeguards
4. Technical Stack
5. Security Model
6. Quality Assurance
7. Publisher Compliance Matrix
8. Attestation & Contact

**What changed since the August 2026 edition**

That edition claimed the platform held zero personal data, that IP addresses were never persisted, that deleting a profile cascaded through every record, that payments went through Stripe, that the app was an installable PWA with an offline cache, and that screenshots and recordings never touched storage. None of that is true today, and some of it was never true. The app is free with no payment surface (ADR-015); the PWA and Web Push were removed (ADR-016). Every statement below was checked against the repository or the production database on the revision date; the data inventory follows ADR-018 and the published Privacy Policy, which prevail in case of disagreement.

## 1. Executive Summary & Scope

### 1.1 Purpose of the Platform

The **FGF Guild Management Platform** is an out-of-game web application that helps guild leaders, officers and players of *Foundation Galactic Frontier* organise rosters, schedule guild events, track attendance and scores, and post announcements to their own Discord servers. It is free for every guild, with no paid tier.

The platform runs **entirely outside** the game client and the game servers. It works in the same capacity as a shared spreadsheet or a community Discord bot.

### 1.2 Foundational Principles

**Game Integrity & Non-Interference**

- ✕ **No client hooks**: no injection into game memory or processes.
- ✕ **No network tampering**: no packet interception.
- ✕ **No automation**: no bots, macros or gameplay actions.
- ✕ **No private APIs**: inputs are what users type or upload.

**Data & IP Safeguards**

- ✓ **Data minimisation**: pseudonyms, player IDs, Discord IDs if linked, 24-hour sign-in IPs.
- ✓ **No game assets**: open-source fonts and icons, self-hosted.
- ✓ **OCR**: screenshots not stored; recordings staged privately, then deleted.
- ✓ **PostgreSQL 17 RLS**: database-enforced tenant isolation.

## 2. Personal Data & Privacy by Design (GDPR)

The operator is established in France, so the GDPR applies whether or not the service is paid. The full notice is the Privacy Policy ( `privacy.html` ), whose inventory is exhaustive.

### 2.1 Data Inventory

| DATA CATEGORY | PROCESSED? | DETAIL |
|---|---|---|
| In-game identity | YES | Pseudonym, in-game player ID (UID), pseudonym-change history (12 months). Online identifiers under GDPR Art. 4(1). |
| Game activity | YES | Attendance, scores, power and ratings, absences, squads, sanctions and bans. |
| Account data | YES | Account identifier, role, guild and server; password stored as a bcrypt hash. A legacy reversibly encrypted copy remains only for accounts not signed in since 2026-10-03, deleted at their next sign-in. |
| Discord identifiers | IF LINKED | Discord user ID and username; OAuth scope `identify` only (no email, no server list). Call-to-arms answers record the Discord user ID for 7 days. |
| IP addresses | 24 HOURS | Sign-in IP stored in `public.login_throttle` for rate limiting, purged hourly by the `login-throttle-retention` job (rows older than 24 hours). No analytics, profiling or geolocation. |
| Free text | YES | Support tickets, wiki pages and comments. |
| Diagnostics | ON ERROR | Error reports to Sentry (EU): error, code path, active guild; credentials stripped. |
| Player email addresses | NO | None collected. Each account's sign-in identity uses a synthetic address derived one-way from the account identifier. |
| Names, address, phone, birth date, ID documents | NO | Never requested. |
| Payment data | NO | The app is free: no checkout, subscription or donation path (ADR-015). |
| Game credentials | NO | Game, Apple or Google credentials are never requested. |
| Location / special categories | NO | No geolocation; no Art. 9 or Art. 10 data. |

#### Retention

Enforced by scheduled database jobs, mainly `gm_apply_data_retention()` daily at 04:30 UTC: sign-in IPs 24 hours; codes, tickets and cached OCR text until expiry; call-to-arms answers 7 days; unactioned guild requests 14 days, their Discord handle erased 90 days after closure; audit log and pseudonym history 12 months; rosters and statistics while the guild uses the service.

#### Erasure

On request, through `gm_erase_player` and `gm_erase_account`. A player is **anonymised**: the pseudonym is replaced by a token from a salt that is never stored, UID and timezone cleared, absences and history deleted; the roster row survives unattributable so guild totals stay valid. Ban records are kept in full, as disclosed (Art. 17(3)).

### No Tracking

No cookies, analytics, advertising SDKs or pixels. Browser storage holds only session and display state, strictly necessary, so no consent banner is required. The CSP `connect-src` limits the browser to the Supabase project and Sentry ingest.

### Processors

Supabase (database, auth, storage, functions; EU database), Vercel (hosting), Google Gemini (OCR, wiki summaries), Discord (sign-in, notifications), Sentry (EU, diagnostics), Render (verification worker). Transfers outside the EU under standard contractual clauses or the EU–US Data Privacy Framework.

# 3. Intellectual Property, Asset & Trademark Safeguards

## 3.1 No Game Assets

- ✕ **No game textures or art**: no ship, hero or item graphics from the game.
- ✕ **No 3D models**, **no audio**, **no game code or shaders**.

## 3.2 Interface Provenance

| COMPONENT | SOURCE | LICENSE |
|---|---|---|
| **Design tokens** | Original token set ( `tokens.css` , `theme.css` ) on Material Design 3 conventions | Original work |
| **Typography** | Inter, Plus Jakarta Sans, JetBrains Mono, self-hosted | SIL Open Font License 1.1 |
| **Icons** | Phosphor Icons ( `@phosphor-icons/web` ), subset font served locally | MIT |
| **Charts** | Hand-written rendering ( `PortalChart.ts` ) | Original work |
| **Game assets** | None | — |

The CSP allows scripts and fonts from the app's own origin only: no external font or script CDN.

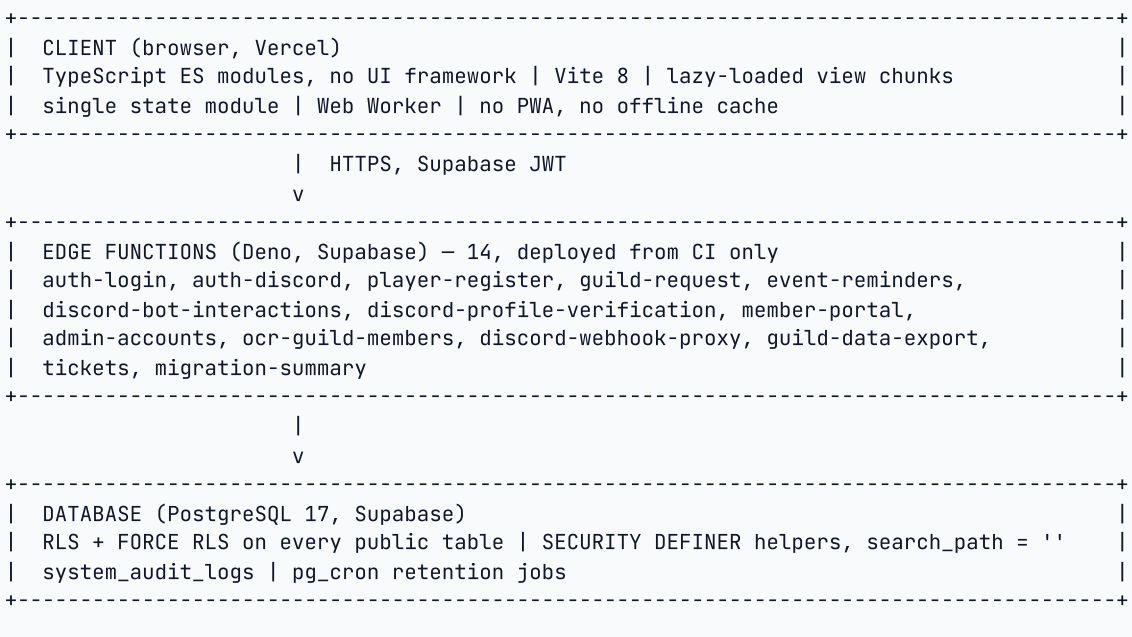
## 3.3 OCR Processing

1. **Screenshots** travel in the request body over TLS to the `ocr-guild-members` Edge Function, are read by Google Gemini for the duration of the request, and are **not stored**. The transcribed text and a SHA-256 fingerprint of the image are cached in `public.ocr_cache` until expiry.
2. **Screen recordings** (MP4, MOV or WebM; at most 64 MiB and 300 s) are uploaded by the browser to the private Storage bucket `ocr-videos` , where RLS lets only that guild's administrators upload, read or delete. The function reads the video with the caller's own token, sends it to the Gemini File API, then deletes the Gemini file and the stored object whatever the outcome; recordings left over from an interrupted scan are removed at the guild's next scan after one hour. Google deletes the file after processing or within 48 hours.
3. **Review before write**: the officer sees a diff against the roster and confirms; a roster import is all-or-nothing.

**Non-Affiliation**

The README and the Terms state that this is an unofficial, community-developed project, not affiliated with or endorsed by the publisher of *Foundation Galactic Frontier*, and that all game names and trademarks belong to their owners.

## 4. Technical Stack




### Client

- Strict TypeScript, Vite
- Views loaded on first use; admin code in its own chunk
- One global only: the frozen e2e entry point
- No PWA; a self-unregistering tombstone service worker

### Edge Functions

- Deno on Supabase
- 14 in the repository, 14 deployed (ADR-017)
- Deployed from CI after every check passes
- Zod-validated inputs

### Database

- PostgreSQL 17 on Supabase
- RLS + FORCE RLS on every table
- Migration history replayed in CI
- Audit log kept 12 months

### 4.1 Logging & Audit

- **Structured logs**: `EdgeLogger` emits JSON with correlation IDs and redacts credentials and tokens; browser errors go through a rate-limited RPC and Sentry with PII scrubbing.
- **Audit trail**: administrative actions write to `public.system_audit_logs`, whose insert is reserved to the service role.

# 5. Security Model

## 5.1 Four Roles

Roles are stored in `public.accounts.role`, limited by a CHECK constraint to four values, and resolved from `auth.uid()` on every request — never from client-supplied data.

| ROLE | SCOPE | ENFORCEMENT |
|---|---|---|
| `super_admin` | All guilds; account provisioning, audit log, ticket console. | `accounts` row resolved from the JWT. |
| `server_admin` | Guilds on their own game server. | RLS helpers compare `guilds.server_number`. |
| `guild_admin` | Their own guild only. | `gm_can_read_guild_data`, `check_user_guild_write_access`. |
| `member` | No direct table access; the Player Portal only. | Every RLS read helper returns false; requests go through the `member-portal` Edge Function. |

## 5.2 Row-Level Security

Every public table has RLS **and** FORCE RLS. Policies call `SECURITY DEFINER` helpers with `SET search_path = ''`, which also refuse a session whose epoch was revoked (password reset, role change, suspension). Tables holding credential material are granted per column.

> **Not a control: `is_subscription_active()`**
> `public.is_subscription_active(p_guild)` still appears in 45 write policies, but it is an inert stub (a literal `SELECT true`, verified on production on 2026-10-04). It gates nothing; the app is free.

## 5.3 Player Portal Isolation

A player signs in with Discord and joins a guild with a join code and their UID, approved by an officer. Direct table queries from a member return nothing. The portal calls `member-portal`, which requires a platform-verified JWT, resolves the account from it (active status and current session epoch required) and derives the player's UID server-side; client-supplied identities are ignored.

## 5.4 Edge Function Protections

- **Authentication**: `verify_jwt` is set per function in `supabase/config.toml`. Seven functions take no Supabase JWT because no session exists yet or the caller is not a user (sign-in, registration, guild requests, the cron-triggered reminder dispatcher, the Discord interactions endpoint verified by Ed25519 signature, the verification worker authenticated by a shared secret); the other seven require one.
- **Input validation**: Zod schemas; scores bounded to 0–9,999,999,999.
- **Rate limits** fail closed (sign-in, portal, OCR video budget).
- **Webhooks**: Discord webhook URLs are stored server-side in `guild_config`, never supplied by the client at send time; only Discord hosts over HTTPS are accepted.
- **Secrets** live in Supabase Vault or function environment variables, never in the repository.

## 6. Quality Assurance

Every push runs the CI pipeline; deployment jobs run only after all checks pass.

```
1. npm run type-check      zero TypeScript errors
2. npm test                Vitest suite, with a coverage floor
3. npm run build           production bundle, with an entry-size budget
4. npx playwright test     end-to-end tests against the built bundle in dist/,
                           incl. axe-core accessibility checks, CSP and asset errors
5. deno check / deno test  Edge Functions against an in-memory Supabase
6. migration replay        PostgreSQL 17 from scratch, schema fingerprint vs production,
                           SQL tests of RLS, grants and RPCs as each role
```

On 2026-10-04 the suite stood at 2,508 Vitest tests and 61 Playwright tests (CHANGELOG, phase M5). The number grows with every change: read the CI run rather than this line.

## 7. Publisher Compliance Matrix

| AREA | REQUIREMENT | IMPLEMENTATION | STATUS |
|---|---|---|---|
| **Personal data** | Lawful, minimal processing (GDPR). | Published inventory, retention jobs and erasure functions (ADR-018). No player emails, payment or location data. | DOCUMENTED |
| **Game modification** | No memory injection, packet tampering or hooks. | External web application; no interaction with the game client. | YES |
| **Automation** | No automated gameplay. | Manual management and voluntary score entry; the Discord bot acts in Discord only. | YES |
| **Copyrighted assets** | No proprietary textures, models, audio or binaries. | OFL fonts, MIT icons, original tokens and charts. | YES |
| **Screenshots & recordings** | Not archived or monetised. | Screenshots not stored; recordings staged privately and deleted after transcription. | YES |
| **Access security** | Tenant isolation. | RLS + FORCE RLS on every table; four server-resolved roles; session revocation. | YES |
| **Network safety** | Safe webhook relaying. | Server-side webhook URLs, Discord hosts only. | YES |
| **Game economy** | No currency manipulation or trading. | No virtual goods, trading or game-server writes; no payments of any kind. | YES |
| **Legal status** | Clear non-affiliation. | Statement in the README and the Terms. | YES |

## 8. Attestation & Contact

**Developer Attestation**

The **FGF Guild Management Platform** is an independent community tool. It supports guild coordination without touching the game client or servers, uses no publisher assets, and processes the limited personal data described in Section 2 under a published Privacy Policy.

**Contact**

Controller and maintainer: André Vieira, **fgfwiki@gmail.com** (the single contact address in the Privacy Policy). Security and compliance concerns sent there are handled with priority.